



Infrastructure Governance Guide for Regulated Organizations

Financial Industry Regulatory Authority (FINRA)

How managed infrastructure is the foundation of every enforceable governance program under FINRA requirements.

1. Why Infrastructure Governance Matters to FINRA

FINRA Rule 4370 and Rule 3110 both depend on managed infrastructure:

- Rule 4370 BCP: Business continuity planning requires knowing which systems are critical, how they fail, and how they recover. Unmanaged infrastructure cannot support a credible BCP.
- Rule 3110 Supervision: Electronic communications, order management, and supervisory reviews all happen on infrastructure. Gaps in infrastructure governance create supervision gaps.
- FINRA Cybersecurity Expectations: FINRA annual examination priorities consistently include infrastructure security including endpoint protection, remote access, and cloud governance.
- Evidence Standard: FINRA examiners expect evidence that infrastructure controls are enforced. MDM compliance reports, patch status dashboards, and access logs are examiner-requested documents.

2. Endpoint and Device Governance Under FINRA

Broker-dealer endpoints must be managed to support supervision, recordkeeping, and business continuity obligations:

- ✓ MDM/UEM enrollment for all endpoints used for firm business. FINRA has cited unmanaged personal devices as supervision gaps.
- ✓ Electronic communications archiving configured at the device level to ensure all firm communications are captured regardless of application used.
- ✓ EDR/XDR with managed detection and response. Required to meet Rule 4370 incident detection requirements.
- ✓ Encryption on all endpoints and removable media to protect customer records in transit.
- ✓ Application controls to prevent installation of unauthorized communications applications that could bypass recordkeeping requirements.

3. Network Infrastructure Under FINRA

Network infrastructure must support FINRA supervision and business continuity requirements:

- Segmentation: Order management and trading systems isolated from general office networks with network access logs for regulated systems.
- Firewall Management: Documented rulesets reviewed quarterly with change management log for all firewall changes.

- Remote Access: MFA-enforced VPN or ZTNA for all remote access with session logging. FINRA has specifically examined remote access security in recent cycles.
- Network Monitoring: IDS/IPS and SIEM ingesting network logs. Required to support the incident detection obligations under Rule 4370.
- Wireless Security: WPA3 or WPA2-Enterprise on corporate wireless with isolated guest network. Document wireless configuration for examination evidence.

4. Records Infrastructure Under FINRA

FINRA rules 4511 and 4512 require electronic records to be maintained in specific format:

- WORM Compliance: Rule 17a-4 requires electronic records to be stored in a non-rewriteable non-erasable format. Your storage infrastructure must meet this requirement.
- Retention Periods: Books and records must be retained for defined periods. 6 years for most broker-dealer records with 3 years in an accessible location.
- Email and Communications Archiving: All electronic communications must be captured and archived. Infrastructure gaps create recordkeeping failures.
- Retrieval Capability: Archived records must be retrievable promptly within 24 hours for recent records. Test your retrieval capability before an examination requests records.
- Backup and Recovery: Rule 4370 requires ability to recover records in a business disruption. Backup infrastructure must be tested and documented.

5. Identity and Access Infrastructure Under FINRA

Access governance is a FINRA examination priority. The technical foundation is identity infrastructure:

- Single Identity Directory: All users provisioned through a single directory. Shadow accounts create supervision gaps and recordkeeping failures.
- MFA Enforcement: MFA on all remote access, email, and financial systems. FINRA has cited missing MFA as a deficiency in multiple examination cycles.
- Access Reviews: Quarterly reviews for trading and financial systems with documentation of exception remediation.
- Terminated Employee Access: Immediate revocation on termination. Access after departure creates both supervision and cybersecurity risks.

- Privileged Access: Admin and privileged accounts logged and reviewed monthly with separate privileged credentials from standard user accounts.

6. FINRA Infrastructure Governance Checklist

Infrastructure governance evidence for FINRA examination readiness:

- MDM enrollment evidence and compliance report for all firm endpoints
- Electronic communications archiving configuration documentation
- Network segmentation documentation for trading and order management systems
- WORM storage compliance evidence for required books and records
- Remote access logs and MFA enrollment evidence
- BCP documentation with infrastructure recovery procedures per Rule 4370
- Access review records quarterly for financial systems
- Terminated employee access termination log

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/financial-services

Call us: (877) 945-7177